Lab 5: Social Engineering Simulation and Phishing Detection

Purpose: Demonstrate how a deceptive login page can collect submitted information in an authorized lab, then examine the evidence and defenses.

Estimated duration: 90-120 minutes

Learning outcomes

1. Explain how phishing uses impersonation, urgency, and trust.

2. Demonstrate a simulated credential submission using dummy data.

3. Identify suspicious features in a message and login page.

4. Collect and interpret evidence of the simulation.

5. Recommend technical and user-focused defenses.

1. Authorization and boundaries

Perform this exercise only within the instructor-approved lab.

• Use only the supplied training website and your assigned virtual machines.

• Use fictional names and dummy credentials. Never enter an existing password.

• Do not clone public websites or university and workplace login portals.

• Do not send messages to real employees, students, or external recipients.

• Do not expose the simulated login page to the internet.

• Preserve logs. Do not attempt to conceal activity or bypass security controls.

• Stop and notify the instructor if real credentials are entered or an unintended person or system becomes involved.

The instructor must identify the permitted systems, participants, and exercise period before work begins.

2. Materials and preparation

You will need:

• A Kali Linux VM with the Social Engineering Toolkit (SET).

• An instructor-supported Windows or Linux client VM with a browser.

• VirtualBox or VMware.

• An instructor-provided mock login website.

• A host-only or internal virtual network.

• A local mail sandbox if email delivery is part of the exercise.

Instructor preparation

1. Test the exercise using the exact VM images and SET version students will use.

2. Supply a mock login website with fictional organization branding and no external dependencies.

3. Provide the training website address, network settings, and expected SET prompts.

4. Supply a local mail sandbox or select direct browser access for the demonstration.

5. Provide disposable VM snapshots and a location for storing evidence.

3. Establish the lab environment

1. Take a snapshot of each VM.

2. Connect the VMs to the assigned isolated virtual network.

3. Disable unnecessary network adapters after installing required software.

4. Record the Kali IP address, client VM IP address, training website address, SET version, and date and time of the exercise.

5. Confirm that the client can open the original training website.

6. Confirm that the systems are within the instructor's approved scope.

Checkpoint: Do not continue until the original training page is accessible and the network configuration has been verified.

4. Prepare the simulated login page

1. Open a terminal in Kali and start SET: `sudo setoolkit`. If prompted, enter the password for your current user account, subject to the VM's configuration.

2. Select the menu entries named **Social-Engineering Attacks**, **Website Attack Vectors**, **Credential Harvester Attack Method**, and **Site Cloner**. Menu numbers may vary by version; follow the labels and instructor guidance.

3. When prompted for the receiving address, enter your Kali VM's address on the isolated lab network.

4. Enter the address of the **instructor-provided training website**.

5. Record the displayed server address and any warnings or errors.

Checkpoint: From the client VM, open the address confirmed by the tool or instructor. Do not assume that a `/login` path exists.

If the page does not load, check the assigned network settings, IP address, server status, and instructor-approved firewall configuration. Record unresolved errors rather than changing security settings without guidance.

5. Examine a simulated phishing message

Use this sample only in the approved local mail sandbox, or save it as a text file if no sandbox is available.

> **Subject: Training Portal Account Review**
>
> Hello Test User,
>
> Please review your fictional training account using the link below:
>
> [Instructor-approved local lab URL]
>
> Training Support

1. Identify where the message claims authority or requests action.

2. Compare the link destination with the original training website.

3. Record at least three checks a recipient could perform before submitting information.

4. If using a mail sandbox, send the message only to your assigned dummy mailbox.

Do not use public email services for this exercise.

6. Perform one controlled submission

1. Open the simulated page from the client VM.

2. Enter these disposable values:

```
Username: student01@example.test
Password: LabOnly-Example-482!
```

3. Submit the form once.

4. Observe SET's output.

5. Record whether the page loaded, whether the submitted dummy values appeared, any browser warning, what happened after submission, and any errors or unexpected behavior.

A captured form submission demonstrates that the receiving server obtained the entered values. It does **not** demonstrate successful access to a real account.

Do not assume that redirection will occur or that it would prevent a user from noticing the deception.

7. Collect and analyze evidence

Preserve evidence before stopping or restoring the VMs. Collect:

• A simple network diagram showing the lab systems.

• A screenshot of the simulated page and its address bar.

• A screenshot of SET's result containing only dummy values.

• Relevant timestamps and available server or browser evidence.

• A brief description of any failed or blocked step.

Explain which evidence supports each conclusion. For example, a page visit alone does not prove that a form was submitted.

If a control blocks the simulation, document the result. Do not attempt to evade it.

8. Evaluate defenses

Answer the following questions:

1. Which message and webpage features could alert a recipient?

2. Which observable events could help an analyst detect the activity?

3. Why should users avoid entering credentials after following an unexpected message link?

4. How could email filtering, reporting tools, password managers, and authentication controls reduce risk?

5. What is the difference between ordinary MFA and phishing-resistant authentication?

6. Why does collecting a password not necessarily mean that an attacker can access an account?

7. What authorization, privacy, evidence-handling, and debriefing requirements should apply to a professional simulation?

8. What does this simplified exercise fail to represent about real phishing incidents?

9. Cleanup and debrief

1. Stop the simulated server.

2. Save the required evidence in the assigned location.

3. Confirm that the evidence contains only dummy data.

4. Close the lab browser and mail sessions.

5. Restore the disposable VM snapshots after preserving your submission.

6. Discuss the results with the instructor.

Do not delete system logs or clear history to conceal the exercise.

If real credentials were entered accidentally, stop the exercise and notify the instructor. Follow the approved incident procedure and change the affected password through the legitimate service.

10. Submission and marking

Submit a short report containing your scope statement, environment details, evidence, results, defense analysis, and cleanup confirmation.

Assessment area	Weight
Authorization and correct lab boundaries	15%
Environment setup and network explanation	20%
Controlled execution and accurate observations	20%
Evidence collection and interpretation	20%
Defensive analysis and reflection	20%
Cleanup and report clarity	5%
Total	**100%**

A blocked or unsuccessful simulation can receive full credit when the setup, evidence, diagnosis, and explanation meet the assessment criteria.

Optional extension: Defender investigation

Using the preserved evidence:

1. Build a timeline of the page visit and dummy submission.

2. Identify which observations indicate a visit and which indicate a submission.

3. Propose one detection rule or alert and explain possible false positives.

4. Recommend one improvement to the lab's monitoring.

5. Explain what additional evidence would be needed to establish account misuse.